

FFUF LAB

This report documents a hands-on FFUF lab focused on web content discovery and fuzzing. The exercises progress from installation and directory enumeration to filtering, matchers, recursive fuzzing, POST-request fuzzing, virtual-host discovery, and auto-calibration.

Installation

```
(root@kali)-[~]
# sudo apt install ffuf -y
Mis à jour :
  ffuf

Sommaire :
  Mise à niveau de : 1. Installation de : 0, Supprimé : 0. Non mis à jour : 11
  43
  Taille du téléchargement : 3 152 ko
  Espace nécessaire : 66,6 ko / 44,2 Go disponible

Réception de : 1 http://kali.download/kali kali-rolling/main amd64 ffuf amd64
2.2.1-1 [3 152 kB]
Ign : 1 http://kali.download/kali kali-rolling/main amd64 ffuf amd64 2.2.1-1
Réception de : 1 http://kali.download/kali kali-rolling/main amd64 ffuf amd64
2.2.1-1 [3 152 kB]
2 156 ko réceptionnés en 2min 12s (16,3 ko/s)
(Lecture de la base de données... 513905 fichiers et répertoires déjà installé
s.)
Préparation du dépaquetage de .../ffuf_2.2.1-1_amd64.deb ...
Dépaquetage de ffuf (2.2.1-1) sur (2.1.0-1+b11) ...
Paramétrage de ffuf (2.2.1-1) ...
Traitement des actions différées (« triggers ») pour man-db (2.13.1-1) ...
Traitement des actions différées (« triggers ») pour kali-menu (2026.3.2) ...
```

Lab setup

```
(root@kali)-[~]
# git clone https://github.com/hacker795/ffuf-lab.git
Clonage dans 'ffuf-lab' ...
remote: Enumerating objects: 138, done.
remote: Counting objects: 100% (138/138), done.
remote: Compressing objects: 100% (106/106), done.
remote: Total 138 (delta 36), reused 59 (delta 0), pack-reused 0 (from 0)
Réception d'objets: 100% (138/138), 28.00 KiO | 868.00 KiO/s, fait.
Résolution des deltas: 100% (36/36), fait.

(root@kali)-[~]
# cd ffuf-lab

(root@kali)-[~/ffuf-lab]
# ls
README.md  setup_ffuf_lab.sh  vhosts  webroot
```

```
root@kali: ~/ffuf-lab
Session Actions Éditer Vue Aide

(root@kali)-[~/ffuf-lab]
# bash setup_ffuf_lab.sh
[+] Updating system...
Réception de : 1 http://kali.download/kali kali-rolling InRelease [34,0 kB]
Réception de : 2 http://kali.download/kali kali-rolling/main amd64 Packages [2
1,6 MB]
Réception de : 3 http://kali.download/kali kali-rolling/main amd64 Contents (d
eb) [54,0 MB]
Réception de : 4 http://kali.download/kali kali-rolling/contrib amd64 Packages
[116 kB]
Réception de : 5 http://kali.download/kali kali-rolling/contrib amd64 Contents
(deb) [270 kB]
Réception de : 6 http://kali.download/kali kali-rolling/non-free amd64 Package
s [183 kB]
Réception de : 7 http://kali.download/kali kali-rolling/non-free amd64 Content
s (deb) [915 kB]
77,2 Mo réceptionnés en 1min 25s (911 ko/s)
1145 paquets peuvent être mis à jour. Exécutez « apt list --upgradable » pour
les voir.
[+] Installing Apache + PHP...
php est déjà la version la plus récente (2:8.4+99).
php passé en « installé manuellement ».
libapache2-mod-php est déjà la version la plus récente (2:8.4+99).
libapache2-mod-php passé en « installé manuellement ».
Mis à jour :
  apache2  apache2-bin  apache2-data  apache2-utils  unzip
```

```

root@kali: ~/ffuf-lab
Session Actions Éditer Vue Aide

systemctl reload apache2
Site localhost already enabled
Enabling site test.local.
To activate the new configuration, you need to run:
systemctl reload apache2
Enabling site wildcard.ffuf.
To activate the new configuration, you need to run:
systemctl reload apache2
[+] Adding hosts entries ...
[+] Testing Apache configuration ...
AH00558: apache2: Could not reliably determine the server's fully qualified do
main name, using 127.0.1.1. Set the 'ServerName' directive globally to suppres
s this message
Syntax OK
[+] Restarting Apache ...

[+] FFUF Lab installation COMPLETE!
Visit: http://localhost/
      http://dev.local
      http://api.local
      http://ffuf.lab

```

```

(root@kali)-[~/ffuf-lab]
# curl http://localhost/

Welcome to FuzzCorp Web Portal

```

```

localhost/ x +
← → ↻ 🏠 Not Secure http://localhost ☆
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Welcome to FuzzCorp Web Portal

```

SecLists installation

```
(root@kali)-[~/ffuf-lab]
# sudo apt install seclists -y
Installation de :
seclists

Sommaire :
  Mise à niveau de : 0. Installation de : 1, Supprimé : 0. Non mis à jour : 11
40
Taille du téléchargement : 545 Mo
  Espace nécessaire : 1 935 Mo / 43,9 Go disponible

Réception de : 1 http://kali.download/kali kali-rolling/main amd64 seclists al
l 2025.3-0kali1 [545 MB]
Ign : 1 http://kali.download/kali kali-rolling/main amd64 seclists all 2025.3-
0kali1
Réception de : 1 http://kali.download/kali kali-rolling/main amd64 seclists al
l 2025.3-0kali1 [545 MB]
46,8 Mo réceptionnés en 14min 49s (52,6 ko/s)
Sélection du paquet seclists précédemment désélectionné.
(Lecture de la base de données... 513904 fichiers et répertoires déjà installé
s.)
Préparation du dépaquetage de .../seclists_2025.3-0kali1_all.deb ...
Dépaquetage de seclists (2025.3-0kali1) ...
Paramétrage de seclists (2025.3-0kali1) ...
Traitement des actions différées (« triggers ») pour kali-menu (2026.3.2) ...
```

Directory enumeration

```

root@kali: ~/ffuf-lab
Session Actions Éditer Vue Aide

(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt

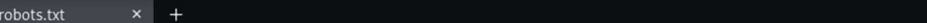
      /\_/\   /\_/\   /\_/\   /\_/\
     /--\   /--\   /--\   /--\
    /___\/   /___\/   /___\/   /___\/
   /_____\   /_____\   /_____\   /_____\
  /_____\/   /_____\/   /_____\/   /_____\/

2.1.0-dev

:: Method           : GET
:: URL              : http://localhost/FUZZ
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects  : false
:: Calibration       : false
:: Timeout           : 10
:: Threads           : 40
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500


.htaccess [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 30ms]
.htpasswd [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 31ms]
.hta [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 39ms]
admin [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 7ms]
api [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 0ms]
backup [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
images [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 3ms]
javascript [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 6ms]
login [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 13ms]
private [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 1ms]
robots.txt [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 4ms]
secret [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 15ms]
server-status [Status: 200, Size: 20865, Words: 547, Lines: 342, Duration: 10ms]
test [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 0ms]
index.php [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1021ms]
:: Progress: [4750/4750] :: Job [1/1] :: 190 req/sec :: Duration: [0:00:02] :: Errors: 0 ::
```

robots.txt



The screenshot shows a web browser window with the address bar displaying 'http://localhost/robots.txt'. The page content is as follows:

```
User-agent: *
Disallow: /private/
Disallow: /admin/old/
Disallow: /backup/
# Note: Do not crawl /secret/ (internal)
```

Admin directory

localhost/admin/ x +

← → ↻ 🏠 Not Secure http://localhost/admin/ ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Admin Panel - Access Restricted

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/admin/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt

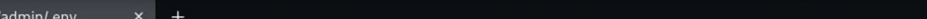
      ^_/_ ^_/_ ^_/_ ^_/_
     /_/_/_/_/_/_/_/_/_/_\
    /_/_/_/_/_/_/_/_/_/_\
   /_/_/_/_/_/_/_/_/_/_\
  /_/_/_/_/_/_/_/_/_/_\
 /_/_/_/_/_/_/_/_/_/_\
/_/_/_/_/_/_/_/_/_/_\

2.1.0-dev

:: Method      : GET
:: URL         : http://localhost/admin/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 9ms]
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 17ms]
.env           [Status: 200, Size: 59, Words: 1, Lines: 4, Duration: 14ms]
credentials.txt [Status: 200, Size: 15, Words: 1, Lines: 2, Duration: 7ms]
index.php      [Status: 200, Size: 120, Words: 16, Lines: 5, Duration: 9ms]
old            [Status: 301, Size: 350, Words: 21, Lines: 10, Duration: 2ms]
:: Progress: [4750/4750] :: Job [1/1] :: 65 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

(root@kali)~[~/ffuf-lab]
#
```



The screenshot shows a web browser window with the address bar displaying 'http://localhost/admin/.env'. The page content shows the following environment variables:

```
DB_USER=dev
DB_PASS=devpass123
SECRET_KEY=ENV_SECRET_98765
```



The screenshot shows a web browser window with the address bar displaying 'http://localhost/admin/credentials.txt'. The page content shows the text 'admin:admin123'.

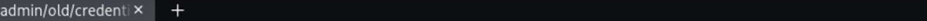
← → ↻ 🏠  Not Secure http://localhost/admin/old/ ☆

🔗 OffSec 🐧 Kali Linux 📖 Kali Tools 📄 Kali Docs 🗨️ Kali Forums 🏹 Kali NetHunter 🔥 Exploit-DB 🔍 Google Hacking DB

Index of /admin/old

Name	Last modified	Size	Description
 Parent Directory		-	
 credentials.txt	2026-09-24 00:09	61	

Apache/2.4.68 (Debian) Server at localhost Port 80



The screenshot shows a web browser window with the address bar displaying 'http://localhost/admin/old/credentials.txt'. The page content shows the following text:

```
username: admin
password: admin123
FLAG{ffuf_lab_basic_flag}
```

Redirects & HTTP status codes

```
(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt
```



```
2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

```
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
admin          [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 1ms]
api            [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 2ms]
backup         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 885ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 894ms]
images         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 3ms]
javascript     [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 0ms]
login          [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 1ms]
private        [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
robots.txt     [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 4ms]
secret         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
```

```
(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -r
```



```
2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : true
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

```
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 5ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 43ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 60ms]
admin          [Status: 200, Size: 120, Words: 16, Lines: 5, Duration: 53ms]
api            [Status: 200, Size: 1291, Words: 89, Lines: 20, Duration: 17ms]
backup         [Status: 200, Size: 1117, Words: 75, Lines: 19, Duration: 8ms]
images         [Status: 200, Size: 1119, Words: 76, Lines: 19, Duration: 29ms]
javascript     [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 23ms]
login          [Status: 200, Size: 288, Words: 19, Lines: 16, Duration: 130ms]
private        [Status: 200, Size: 1119, Words: 75, Lines: 19, Duration: 46ms]
robots.txt     [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 1ms]
server-status  [Status: 200, Size: 22023, Words: 565, Lines: 358, Duration: 3ms]
```


Basic filtering techniques

A filter removes unwanted responses automatically.

Examples:

- • Remove 403 responses
- • Remove default error pages
- • Remove same-size responses
- • Remove same word-count responses

```
FILTER OPTIONS:
-fc      Filter HTTP status codes from response. Comma separated list of codes and ranges
-fl      Filter by amount of lines in response. Comma separated list of line counts and ranges
-fmode   Filter set operator. Either of: and, or (default: or)
-fr      Filter regexp
-fs      Filter HTTP response size. Comma separated list of sizes and ranges
-ft      Filter by number of milliseconds to the first response byte, either greater or less than. EG: >100 or <100
-fw      Filter by amount of words in response. Comma separated list of word counts and ranges
```

```
ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fc 403
```



2.1.0-dev

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response status: 403
```

```
admin      [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 0ms]
api        [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 1ms]
backup     [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
images     [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 2ms]
javascript [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 1ms]
login      [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 0ms]
private    [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
robots.txt [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 1ms]
secret     [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
server-status [Status: 200, Size: 21721, Words: 565, Lines: 358, Duration: 8ms]
test       [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 0ms]
index.php  [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1015ms]
```

```
(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fc 403,301

  _____
 /_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \

2.1.0-dev

:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response status: 403,301

robots.txt      [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 4ms]
server-status  [Status: 200, Size: 21711, Words: 565, Lines: 358, Duration: 3ms]
index.php      [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1021ms]
:: Progress: [4750/4750] :: Job [1/1] :: 71 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

(root@kali)-[~/ffuf-lab]
#
```

```
(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fs 346

  _____
 /_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \
/_ _ _ _ _ \

2.1.0-dev

:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 346

.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 2ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 6ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 4ms]
api            [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 2ms]
backup         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 4ms]
images         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
javascript     [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 0ms]
private        [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 3ms]
robots.txt     [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 4ms]
secret         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
server-status  [Status: 200, Size: 21688, Words: 565, Lines: 358, Duration: 6ms]
```



```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fr "Welcome"
```



2.1.0-dev

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Regexp: Welcome
```

```
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 14ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 11ms]
.htpasswd     [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 2ms]
admin         [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 18ms]
api           [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 2ms]
backup        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 5ms]
images        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 4ms]
javascript    [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 1ms]
login         [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 2ms]
private       [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 2ms]
secret        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
```

```
javascript    [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 1ms]
login         [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 2ms]
private       [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 2ms]
secret        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
robots.txt    [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 52ms]
server-status [Status: 200, Size: 2247, Words: 565, Lines: 358, Duration: 17ms]
test          [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 5ms]
:: Progress: [4750/4750] :: Job [1/1] :: 533 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fc 403 -fl 6
```



2.1.0-dev

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response status: 403
:: Filter      : Response lines: 6
```

```
admin         [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 3ms]
api           [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 5ms]
backup        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
images        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
javascript    [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 2ms]
login         [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 1ms]
private       [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
secret        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 4ms]
server-status [Status: 200, Size: 21717, Words: 565, Lines: 358, Duration: 6ms]
test          [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 2ms]
```

```
secret [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 4ms]
server-status [Status: 200, Size: 21717, Words: 565, Lines: 358, Duration: 6ms]
test [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 2ms]
index.php [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1023ms]
:: Progress: [4750/4750] :: Job [1/1] :: 44 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fc 403 -fl 6 -fmode and
```



2.1.0-dev

```
:: Method : GET
:: URL : http://localhost/FUZZ
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response status: 403
:: Filter : Response lines: 6
```

```
.htaccess [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 5ms]
admin [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 3ms]
api [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 0ms]
backup [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
.hta [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 361ms]
images [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 2ms]
.htpasswd [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 601ms]
javascript [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 2ms]
login [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 1ms]
```

```
login [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 1ms]
private [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 2ms]
robots.txt [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 1ms]
secret [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 3ms]
server-status [Status: 200, Size: 21702, Words: 565, Lines: 358, Duration: 6ms]
test [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 7ms]
index.php [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1015ms]
:: Progress: [4750/4750] :: Job [1/1] :: 60 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fc 403 -fl 10 -fmode and
```



2.1.0-dev

```
:: Method : GET
:: URL : http://localhost/FUZZ
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response status: 403
:: Filter : Response lines: 10
```

```
admin [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 0ms]
api [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 1ms]
backup [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
images [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 3ms]
javascript [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 2ms]
login [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 3ms]
private [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
robots.txt [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 2ms]
```

```

robots.txt      [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 2ms]
secret         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 6ms]
server-status  [Status: 200, Size: 21762, Words: 565, Lines: 358, Duration: 4ms]
test           [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 3ms]
index.php      [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1023ms]
:: Progress: [4750/4750] :: Job [1/1] :: 62 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

```

Matchers & HTTP status codes

Matchers display results that satisfy defined conditions.

```

(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -mc 200

```



2.1.0-dev

```

:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200

```

```

robots.txt      [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 4ms]
server-status   [Status: 200, Size: 21748, Words: 565, Lines: 358, Duration: 5ms]
index.php       [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1026ms]
:: Progress: [4750/4750] :: Job [1/1] :: 55 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

```

```

(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -mc 200,301

```



2.1.0-dev

```

:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,301

```

```

admin          [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 0ms]
api            [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 0ms]
backup         [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
images        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
javascript     [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 2ms]
login         [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 1ms]
private       [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 0ms]
robots.txt    [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 3ms]
secret        [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
server-status [Status: 200, Size: 21771, Words: 565, Lines: 358, Duration: 4ms]
test          [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 1ms]
index.php     [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1006ms]
:: Progress: [4750/4750] :: Job [1/1] :: 52 req/sec :: Duration: [0:00:05] :: Errors: 0 ::

```



```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -ml 6
```

```
2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration   : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response lines: 6
```

```
robots.txt           [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 1ms]
:: Progress: [4750/4750] :: Job [1/1] :: 3773 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

Advanced matchers & modes

```
(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -mr "Welcome"

      _____
     /  _  \   ____\
    /  ___ \  / __ \|
   /  / ___\/ /_ /_/ 
  /_____\___/_____/\

2.1.0-dev

:: Method           : GET
:: URL              : http://localhost/FUZZ
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects  : false
:: Calibration       : false
:: Timeout           : 10
:: Threads           : 40
:: Matcher           : Regexp: Welcome

index.php [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1215ms]
:: Progress: [4750/4750] :: Job [1/1] :: 83 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

```
(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -mt ">500"

      _____
     /  _  \   ____\
    /  /_\  \ / __ \|
   /_____\  \/ / ___|
          \_/\___|_|
           \_____

2.1.0-dev

:: Method       : GET
:: URL          : http://localhost/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response time: >500

index.php [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1023ms]
:: Progress: [4750/4750] :: Job [1/1] :: 579 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -mc 200 -ms 116 -mmode and
```



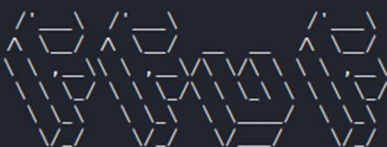
```
2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200
:: Matcher     : Response size: 116
```

```
robots.txt          [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 2ms]
:: Progress: [4750/4750] :: Job [1/1] :: 58 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

Recursive fuzzing with FFUF

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -recursion
```



```
2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
```

```
.htaccess [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 9ms]
.hta      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 2ms]
.htpasswd [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
admin     [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 2ms]
[INFO] Adding a new job to the queue: http://localhost/admin/FUZZ

api       [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 1ms]
[INFO] Adding a new job to the queue: http://localhost/api/FUZZ

backup   [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 0ms]
[INFO] Adding a new job to the queue: http://localhost/backup/FUZZ
```

```
.htaccess           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 3ms]
.hta                [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 4ms]
.htpasswd           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 15ms]
[INFO] Starting queued job on target: http://localhost/test/FUZZ

.htaccess           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
.hta                [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 3ms]
.htpasswd           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 2ms]
[INFO] Starting queued job on target: http://localhost/admin/old/FUZZ

.htpasswd           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 5ms]
.hta                [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 7ms]
.htaccess           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 25ms]
credentials.txt     [Status: 200, Size: 61, Words: 3, Lines: 4, Duration: 16ms]
[INFO] Starting queued job on target: http://localhost/api/v1/FUZZ

.htaccess           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 2ms]
.htpasswd           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 5ms]
.hta                [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 7ms]
[INFO] Starting queued job on target: http://localhost/api/v2/FUZZ

.hta                [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 3ms]
.htaccess           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 4ms]
.htpasswd           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 0ms]
[INFO] Starting queued job on target: http://localhost/javascript/jquery/FUZZ

.htaccess           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 3ms]
.htpasswd           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 2ms]
.hta                [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 33ms]
jquery              [Status: 200, Size: 285284, Words: 35323, Lines: 10715, Duration: 392ms]
:: Progress: [4750/4750] :: Job [14/14] :: 2150 req/sec :: Duration: [0:00:01] :: Errors: 0 ::

(root@kali)-[~/ffuf-lab]
```

Controlling recursive depth

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -recursion -recursion-depth 1

      /\_/\
     (oo)\_____)
    (__)(       )\/\
   ||----w |
   ||     ||

2.1.0-dev

:: Method           : GET
:: URL              : http://localhost/FUZZ
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration      : false
:: Timeout           : 10
:: Threads           : 40
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500

.htpasswd [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 2ms]
admin [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 1ms]
[INFO] Adding a new job to the queue: http://localhost/admin/FUZZ

api [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 0ms]
[INFO] Adding a new job to the queue: http://localhost/api/FUZZ

backup [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
[INFO] Adding a new job to the queue: http://localhost/backup/FUZZ

.htaccess [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 627ms]
```

```

.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 5ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 7ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 7ms]
[INFO] Starting queued job on target: http://localhost/javascript/FUZZ

.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 3ms]
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 10ms]
jquery         [Status: 301, Size: 358, Words: 21, Lines: 10, Duration: 2ms]
[WARN] Directory found, but recursion depth exceeded. Ignoring: http://localhost/javascript/jquery/
[INFO] Starting queued job on target: http://localhost/login/FUZZ

.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 0ms]
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 6ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 10ms]
index.php      [Status: 200, Size: 288, Words: 19, Lines: 16, Duration: 77ms]
[INFO] Starting queued job on target: http://localhost/private/FUZZ

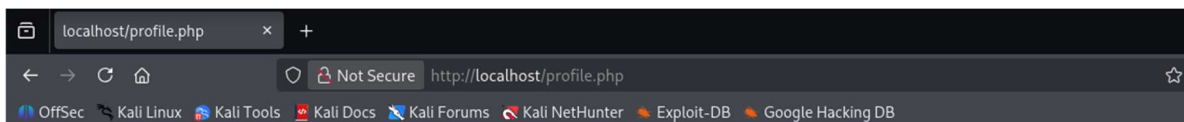
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 0ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 3ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
[INFO] Starting queued job on target: http://localhost/secret/FUZZ

.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 4ms]
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 1ms]
[INFO] Starting queued job on target: http://localhost/test/FUZZ

.htpasswd      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 3ms]
.htaccess      [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 9ms]
.hta           [Status: 403, Size: 314, Words: 21, Lines: 10, Duration: 10ms]
:: Progress: [4750/4750] :: Job [10/10] :: 2898 req/sec :: Duration: [0:00:01] :: Errors: 0 ::

(root@kali)-[~/ffuf-lab]
#

```



User endpoint loaded. Try accessing with valid parameters.

```

(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/profile.php?FUZZ-1 -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt

  _____
 /_ _ _   _/
/_ _ _ _/_/

2.1.0-dev

:: Method      : GET
:: URL         : http://localhost/profile.php?FUZZ-1
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

2
Address      [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 11ms]
AddressStatus [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 12ms]
AuthItem     [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 15ms]
14           [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 7ms]
AudioPlayerSubmit [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 21ms]
ACCESSLEVEL  [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 9ms]
AssignmentForm [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 26ms]
Article      [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 11ms]
AUTH         [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 27ms]
AuthItemChild [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 22ms]
AuthItemChild [Status: 200, Size: 58, Words: 8, Lines: 1, Duration: 2ms]

```

[illegible]

localhost/profile.php?id=1

User Profile ID: 1

```
(root@kali)-[~/ffuf-lab]
# ffuf -u http://localhost/profile.php?id=FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt
```



```
2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://localhost/profile.php?id=FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

```
.bash_history [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 2ms]
.config       [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 4ms]
.env          [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 6ms]
.cvs         [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 11ms]
.gitconfig   [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 12ms]
.git_release [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 14ms]
.git-rewrite [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 13ms]
.git         [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 13ms]
.swf         [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 15ms]
.gitkeep     [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 2ms]
.gitk        [Status: 200, Size: 25, Words: 5, Lines: 1, Duration: 3ms]
```

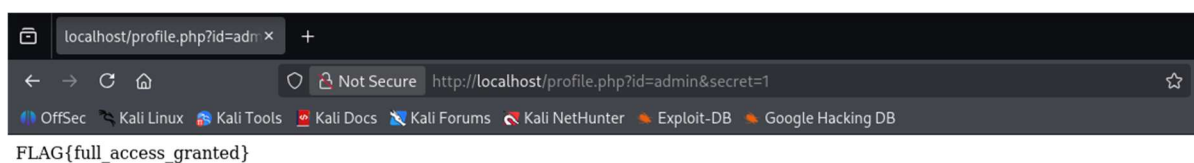
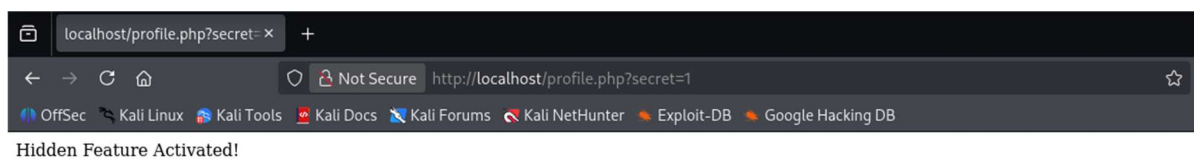
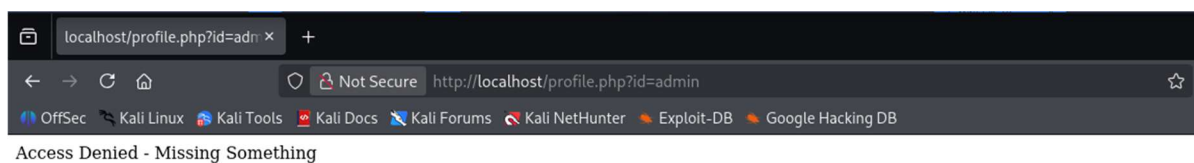
```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/profile.php?id=FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fs 25 -fw 4

      _____
     /  _  /  _  /
    /  /  /  /  /
   /  /  /  /  /
  /  /  /  /  /
 /  /  /  /  /
/  /  /  /  /

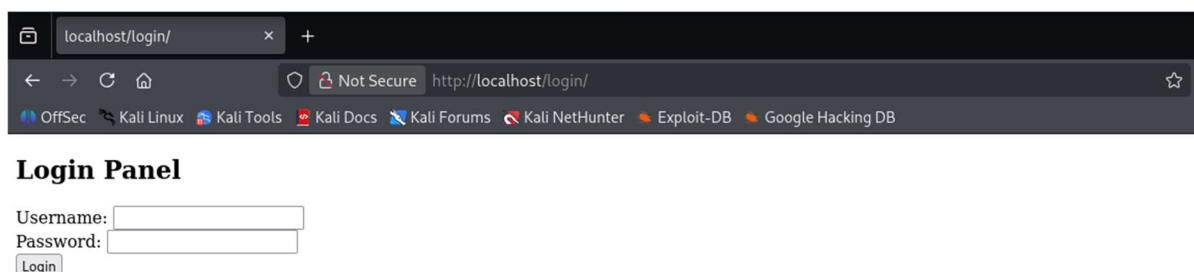
2.1.0-dev

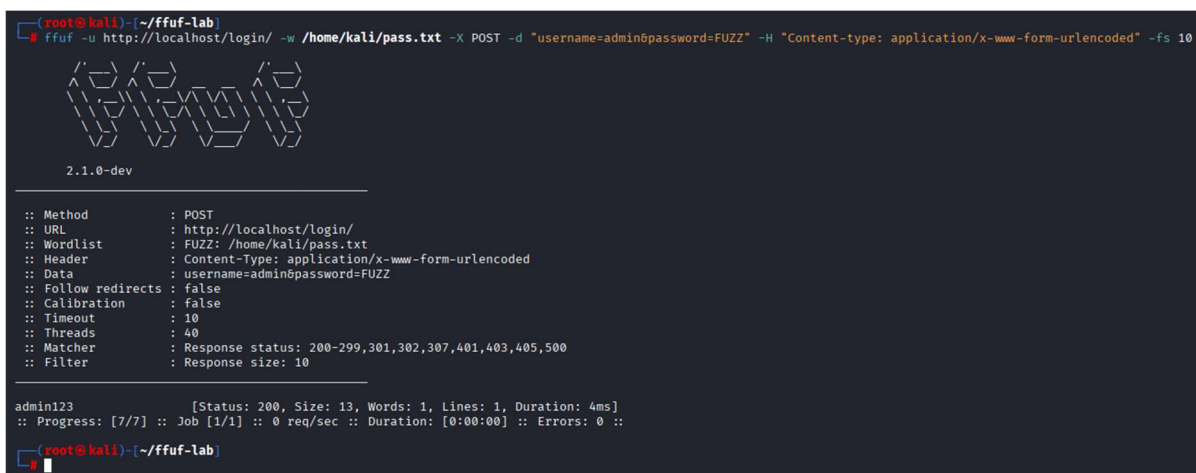
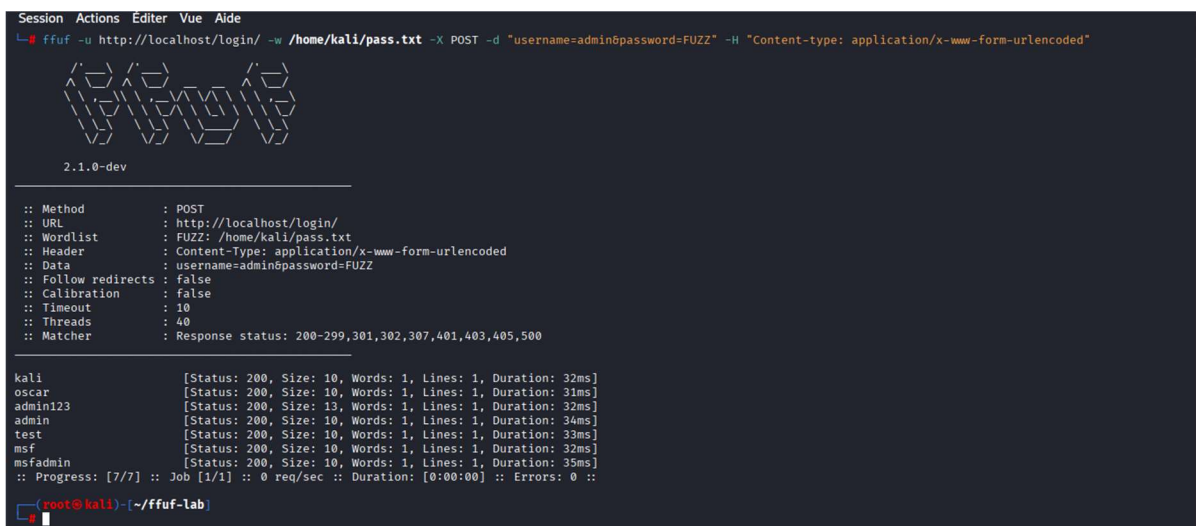
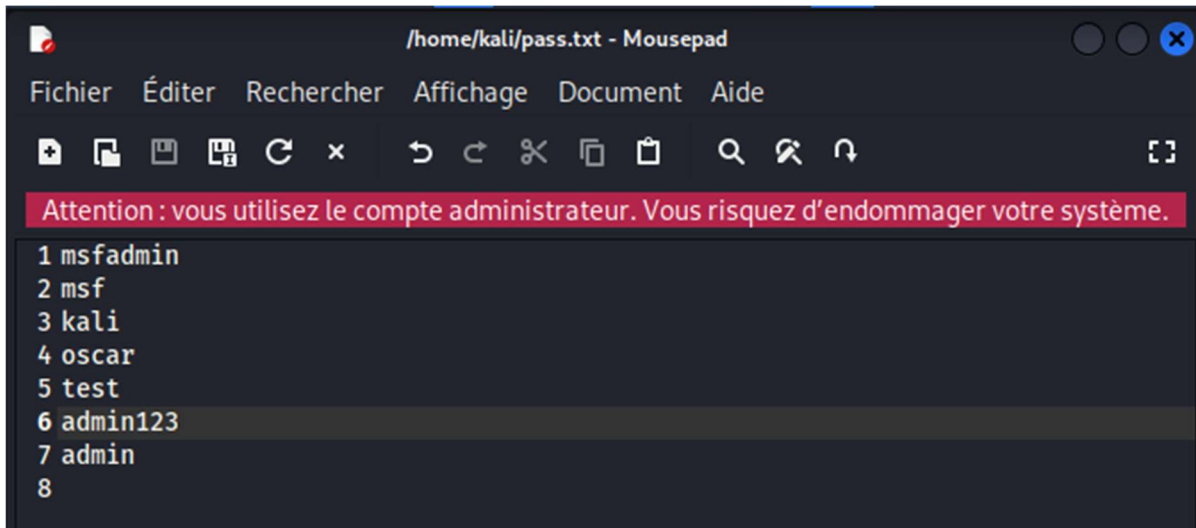
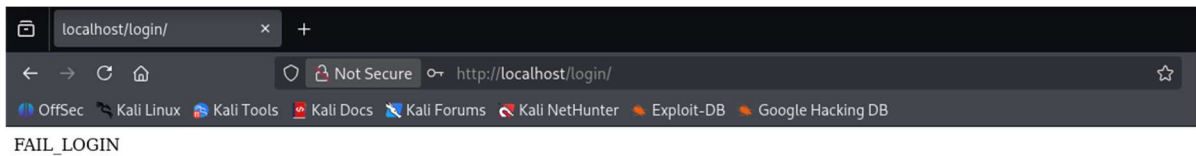
:: Method      : GET
:: URL         : http://localhost/profile.php?id=FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 25
:: Filter      : Response words: 4

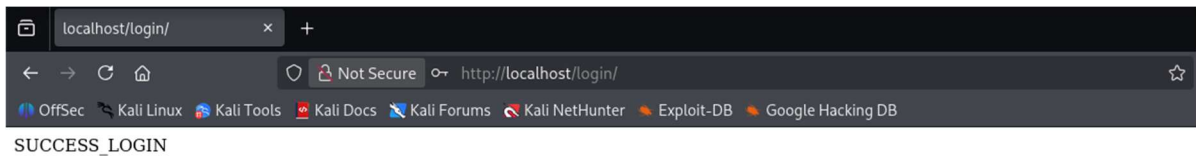
admin      [Status: 200, Size: 33, Words: 5, Lines: 1, Duration: 1ms]
backup     [Status: 200, Size: 19, Words: 3, Lines: 1, Duration: 0ms]
debug      [Status: 200, Size: 18, Words: 3, Lines: 1, Duration: 1ms]
:: Progress: [4750/4750] :: Job [1/1] :: 66 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```



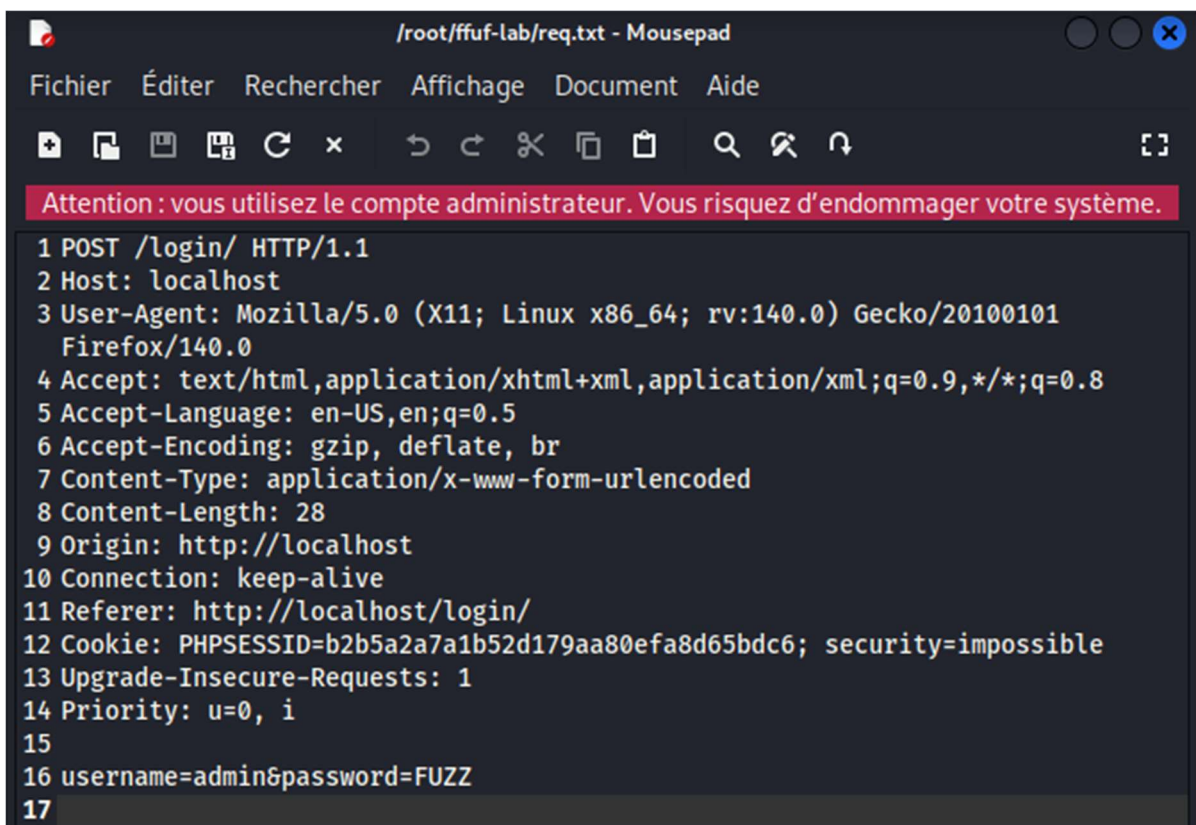
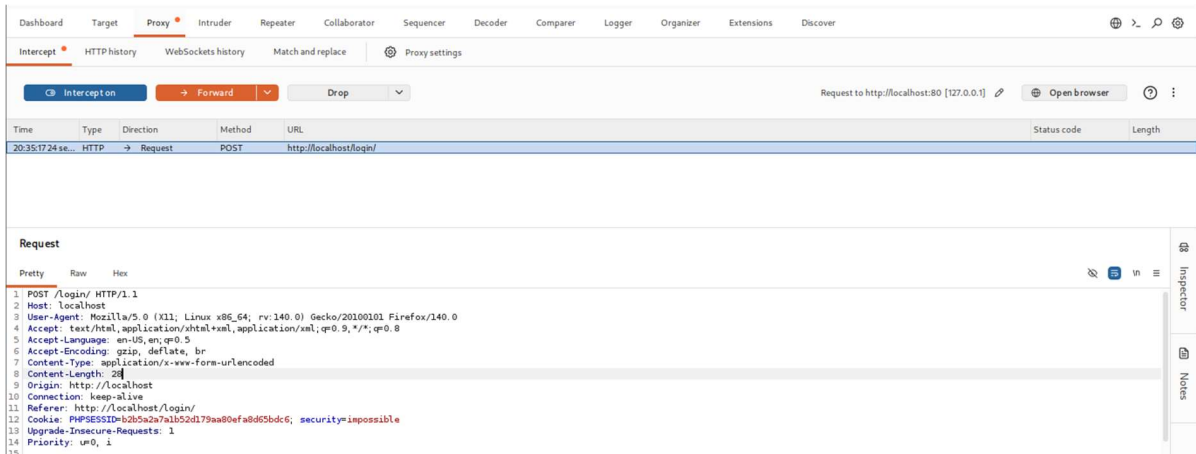
Fuzzing POST requests







Fuzzing real requests



```
(root@kali)~[~/ffuf-lab]
# ffuf -request req.txt -request-proto http -w /home/kali/pass.txt -r -mr "SUCCESS"

      _____
     /  _  _  _  \
    /  /  _  _  \
   /  /  _  _  \
  /  /  _  _  \
 /  /  _  _  \
/  /  _  _  \

2.1.0-dev

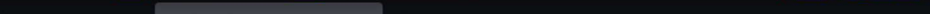
:: Method      : POST
:: URL         : http://localhost/login/
:: Wordlist     : FUZZ: /home/kali/pass.txt
:: Header      : User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
:: Header      : Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
:: Header      : Accept-Language: en-US,en;q=0.5
:: Header      : Referer: http://localhost/login/
:: Header      : Cookie: PHPSESSID=b2b5a2a7a1b52d179aa80efa8d65bdc6; security=impossible
:: Header      : Priority: u=0, i
:: Header      : Host: localhost
:: Header      : Accept-Encoding: gzip, deflate, br
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Header      : Origin: http://localhost
:: Header      : Connection: keep-alive
:: Header      : Upgrade-Insecure-Requests: 1
:: Data        : username=admin&password=FUZZ
:: Follow redirects : true
:: Calibration    : false
:: Timeout       : 10
:: Threads       : 40
:: Matcher       : Regexp: SUCCESS

:: Follow redirects : true
:: Calibration      : false
:: Timeout          : 10
:: Threads          : 40
:: Matcher          : Regexp: SUCCESS

admin123 [Status: 200, Size: 13, Words: 1, Lines: 1, Duration: 187ms]
:: Progress: [7/7] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::

SUCCESS_LOGIN
```

Finding hidden virtual hosts

[illegible]

The screenshot shows a web browser window with the address bar displaying "http://test.local" and a "Not Secure" warning. Below the address bar, there are several bookmarks including "OffSec", "Kali Linux", "Kali Tools", "Kali Docs", "Kali Forums", "Kali NetHunter", "Exploit-DB", and "Google Hacking DB". The main content area displays "Welcome to Test Site".

```
(root@kali)~[/ffuf-lab]
# ffuf -u http://localhost/ -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt -H "Host: FUZZ.local"

2.1.0-dev

:: Method      : GET
:: URL         : http://localhost/
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt
:: Header      : Host: FUZZ.local
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

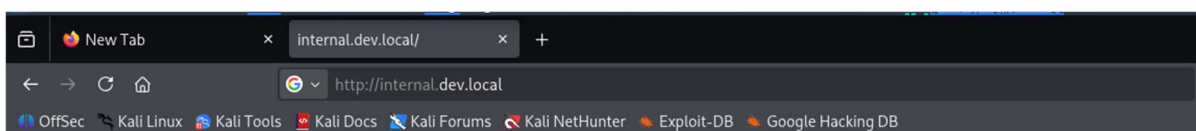
ftp          [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 6ms]
ns2          [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 8ms]
webdisk     [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 8ms]
mobile      [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 10ms]
imap        [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 1ms]
localhost   [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 9ms]
ns4         [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 9ms]
m           [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 9ms]
dev         [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 1ms]
mail2       [Status: 200, Size: 20, Words: 4, Lines: 2, Duration: 1ms]
```

```
(root@kali)~[/ffuf-lab]
# ffuf -u http://localhost/ -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt -H "Host: FUZZ.local" -fs 20

2.1.0-dev

:: Method      : GET
:: URL         : http://localhost/
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt
:: Header      : Host: FUZZ.local
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 20

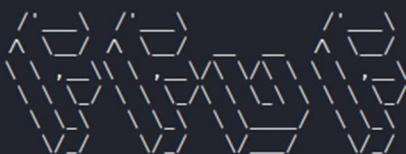
test        [Status: 200, Size: 21, Words: 4, Lines: 2, Duration: 973ms]
internal.dev [Status: 200, Size: 31, Words: 5, Lines: 2, Duration: 9ms]
:: Progress: [114442/114442] :: Job [1/1] :: 2597 req/sec :: Duration: [0:01:10] :: Errors: 0 ::
```



Internal Dev Panel - Forbidden

Auto-calibration with FUZZ (-ac)

```
(root@kali)~[~/ffuf-lab]
# ffuf -u http://localhost/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -ac
```



```
2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://localhost/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : true
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

```
admin       [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 2ms]
api         [Status: 301, Size: 344, Words: 21, Lines: 10, Duration: 2ms]
backup      [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 4ms]
images      [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 1ms]
javascript  [Status: 301, Size: 351, Words: 21, Lines: 10, Duration: 1ms]
login       [Status: 301, Size: 346, Words: 21, Lines: 10, Duration: 3ms]
private     [Status: 301, Size: 348, Words: 21, Lines: 10, Duration: 2ms]
robots.txt  [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 8ms]
secret      [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 2ms]
server-status [Status: 200, Size: 22074, Words: 565, Lines: 358, Duration: 5ms]
```

```
robots.txt  [Status: 200, Size: 116, Words: 11, Lines: 6, Duration: 8ms]
secret      [Status: 301, Size: 347, Words: 21, Lines: 10, Duration: 2ms]
server-status [Status: 200, Size: 22074, Words: 565, Lines: 358, Duration: 5ms]
test        [Status: 301, Size: 345, Words: 21, Lines: 10, Duration: 4ms]
index.php   [Status: 200, Size: 30, Words: 5, Lines: 1, Duration: 1014ms]
:: Progress: [4750/4750] :: Job [1/1] :: 757 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

Web Content Discovery & Fuzzing

Practical cybersecurity lab report

Topics covered

- Installation & lab setup
- Directory and extension enumeration
 - Filtering & matchers
 - Recursive fuzzing
- POST request fuzzing
- Virtual host discovery
 - Auto-calibration